

Homework 3 (90pt)

1. What is the “same-origin policy”? (10pts)
2. RJ, a web programmer for a bank, has been given the task of building the online banking web site. He needs to create an authentication web application that accepts user input of username and passwords and verifies the input. RJ is told to use authentication cookies so that the web application does not frequently re-authenticate users. He generates a random number S only once, and then increases S by a constant value of $0x5f$ to create the cookie for each user. For example, the authentication cookies for user 1, 2, 3, ... are $S + 0x5f$, $S + 0x5f + 0x5f$, $S + 0x5f + 0x5f + 0x5f$..., respectively. Please describe an attack that exploits RJ's implementation to compromise other users' accounts and discuss a possible solution to address this attack. (10 pts)
3. Textbook page 198: Consider a scenario in which an attacker is interested in breaking into Windows NT or UNIX shell accounts. Analyze the technical issues surrounding the password security that these operating systems offer. State your assumptions.
 - a. How many bits of information are possible in an eight-character password if any character can be used? (Assume each character consists of 8 bits) (3pts)
 - b. How many different combinations of passwords are there in an eight-character password if only the uppercase and lowercase characters plus the ten decimal digits can be used? (3pts)
 - c. How many different combinations of passwords are there if users choose their passwords to be concatenations of dictionary words from a dictionary with the characteristics in Table 11-1? (4pts)

Table 11-1. Dictionary of Words

Number of Characters in Word	Number of Words
1	5
2	32
4	103
5	402

4. Would it be possible to thwart all possible password cracking attacks by increasing the salt length to something large, like 64 bits? (10pts)
5. What is an Advanced Persistent Threat (APT)? Which tool we have discussed so far can be used to mitigate this threat? Please explain this tool. (10pts)
6. Programmer RJ tries to design a network protocol to enable a client to check whether a server is still active. He creates a protocol in this way. The client generates a random string and sends the string together with the string length to the server. If the server is still active, the server will echo the string back to the client so that the client knows that the connection is not lost. The server uses the `string_process` function below to process the string. The function first creates a buffer of the size equal to `strlen`, which is the string length sent by the client, and then it copies the input string (the one sent by the client) of size `strlen` to the buffer. The `echo_string` function sends the content in the buffer to the client. This code has a vulnerability that can be exploited by an adversary to cause severe consequences. Please identify the vulnerability, discuss a solution, and explain your reason. (10pts)

```
void string_process (unsigned char *string, unsigned int strlen)
{
    unsigned char *buffer;
    buffer = (unsigned char *) malloc (strlen);
    memcpy (buffer, string, strlen);
    echo_string (buffer, strlen);
    return;
}
```

7. If an organization uses network-based IDS to detect attacks, and it can monitor all incoming and outgoing traffic, is there any value to also using host-based IDS? If so, why, and if not, why not? (10pts)
8. One approach to defeat the tiny fragment attack against firewall packet filtering is to enforce a minimum length of the transport header that must be contained in the first fragment of an IP packet. If the first fragment is rejected, all subsequent fragments can be rejected. However, the nature of TCP is that fragments may arrive out of order. Thus, an intermediate fragment may pass through the filter before the initial fragment is rejected. How can this situation be handled? (10pts)
9. Eve, a hacker, uses some automatic tool to scan existing popular web pages to search for the SQL injection vulnerability. Eve finds a webpage with the URL below

<http://oceanbaynews.com/music.php?id=3153>

From the URL, Eve guesses that this URL sends a search query to some database to search a table of the name 'music'. The search query may look like this

Select * from music where id = 3153

Eve wants to know what information is stored in this database. So, he wants to know the names of all tables, and the names of all table columns. Please compose malicious URL with the SQL injection payload that can display this information to Eve. Please also propose a defense method to prevent this attack. (10pts)